

Manual da API

Referencia das rotas HTTP do Portal de Gestao de Dados

Gerado em: 21/07/2026

Base: /api

Autenticacao: JWT HS256 (Bearer)

1. Fundamentos

Todas as rotas ficam sob o prefixo /api, resolvido pelo front controller index.php. O portal funciona em subpasta: se estiver em http://servidor/dados, a base e http://servidor/dados/api.

Requisicoes e respostas usam JSON. Os erros seguem sempre o mesmo formato, com a mensagem em erro:

```
{ "erro": "Usuario ou senha invalidos." }
```

Autenticacao

O login devolve um token JWT que deve acompanhar as demais chamadas:

```
Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9...
```

O token carrega exp (validade) e iat (emissao). A emissao permite a revogacao em massa: ao trocar a senha, o servidor grava um corte e recusa qualquer token emitido antes dele. O logout revoga so o token em uso, pelo jti.

Codigos de resposta

Codigo	Significado
200	Sucesso, com corpo JSON.
201	Registro criado.
204	Sucesso sem corpo (exclusoes).
400	Requisicao malformada ou operacao invalida.
401	Sem token, token invalido ou expirado.
403	Autenticado, mas sem permissao para a acao.
404	Rota ou registro inexistente.

Codigo	Significado
422	Dados recusados na validacao.
429	Limite de tentativas ou de reenvios atingido.

Papeis

Papel	Pode fazer
leitura	Consultar os modulos liberados para a conta.
escrita	Consultar e manter registros dos modulos liberados.
admin	Tudo do escrita, mais usuarios, listas e configuracao.
master	Tudo do admin, mais a trilha de auditoria e acoes sobre outro master.

Nao ha um portao unico de autorizacao: cada rota chama explicitamente `exigirLogin()`, `exigirAdmin()` ou `exigirMaster()`. Ao criar uma rota nova, essa chamada e obrigatoria -- sem ela a rota fica publica.

2. Sessao e conta

POST /auth/login

Acesso: publica

Autentica e devolve o token. Se a conta usa verificacao em duas etapas, nao devolve token: manda um codigo por e-mail e responde com um token de verificacao temporario.

Requisicao

```
{
  "usuario": "admin",
  "senha": "SenhaForte1"
}
```

Resposta

```
{
  "token": "eyJ0eXAiOiJKV1Qi...",
  "usuario": {
    "id": 1,
    "username": "admin",
    "role": "master"
  }
}
```

Falhas sao limitadas a 5 por usuario+IP e 20 por IP, com bloqueio temporario. A resposta nao diz se o erro foi no login ou na senha, para nao revelar contas validas.

POST /auth/mfa/verificar

Acesso: publica

Confere o código de seis dígitos e conclui o login.

Requisicao

```
{
  "token": "a1b2c3...",
  "codigo": "482915"
}
```

Resposta

```
{
  "token": "eyJ0eXAiOiJKV1Qi...",
  "usuario": { "id": 1, "username": "admin" }
}
```

O código vale 10 minutos e aceita no máximo 5 conferências. É guardado apenas como HMAC de "token|codigo".

POST /auth/mfa/reenviar

Acesso: publica

Reenvia o código. Intervalo mínimo de 60 segundos e teto de 5 reenvios por sessão de login.

Requisicao

```
{ "token": "a1b2c3..." }
```

Resposta

```
{ "ok": true }
```

GET /auth/me

Acesso: qualquer conta autenticada

Dados da conta em uso, incluindo se ela tem foto.

Resposta

```
{
  "id": 1,
  "username": "admin",
  "nome_completo": "Administrador",
  "role": "master",
  "modulos_permitidos": "acessos,jobs",
  "mfa_ativo": 0,
  "tem_foto": true
}
```

PUT /auth/me

Acesso: qualquer conta autenticada

Atualiza nome, e-mail e preferencias visuais da propria conta.

Requisicao

```
{
  "nome_completo": "Administrador",
  "email": "admin@empresa.com",
  "cor_tema": "padrao"
}
```

Resposta

```
{ "ok": true }
```

POST /auth/change-password

Acesso: qualquer conta autenticada

Troca a senha. Invalida todos os tokens anteriores, inclusive em outros dispositivos.

Requisicao

```
{
  "senha_atual": "SenhaAntiga1",
  "senha_nova": "SenhaForte2"
}
```

Resposta

```
{ "ok": true }
```

POST /auth/logout

Acesso: qualquer conta autenticada

Revoga o token em uso.

Resposta

204 sem corpo

3. Usuarios

GET /usuarios

Acesso: admin

Lista as contas. A senha nunca e devolvida.

Resposta

```
[
  {
    "id": 1,
    "username": "admin",
    "role": "master",
    "ativo": 1,
    "tem_foto": true
  }
]
```

POST /usuarios

Acesso: admin

Cria uma conta.

Requisicao

```
{
  "username": "maria",
  "nome_completo": "Maria Silva",
  "email": "maria@empresa.com",
  "senha": "SenhaForte1",
  "role": "escrita",
  "modulos_permitidos": "acessos,jobs"
}
```

Resposta

```
{ "id": 7 }
```

PUT /usuarios/{id}

Acesso: admin

Atualiza a conta. Enviar a senha em branco mantem a atual.

Requisicao

```
{
  "nome_completo": "Maria S. Silva",
  "role": "admin",
  "ativo": 1
}
```

Resposta

```
{ "ok": true }
```

So o master concede ou remove o papel master.

DELETE /usuarios/{id}

Acesso: admin

Remove a conta e a foto associada. Nao e possivel remover a si mesmo, e so o master remove outro master.

Resposta

```
204 sem corpo
```

PATCH /usuarios/{id}/ativo

Acesso: admin

Ativa ou desativa a conta sem apagar o historico.

Requisicao

```
{ "ativo": 0 }
```

Resposta

```
{ "ok": true }
```

PUT /usuarios/{id}/permissoes

Acesso: admin

Define papel e modulos liberados.

Requisicao

```
{
  "role": "escrita",
  "modulos_permitidos": "acessos, backup, jobs"
}
```

Resposta

```
{ "ok": true }
```

Foto do usuario

A foto fica no banco, em tabela propria, e trafega como data URI dentro do JSON -- e nao como arquivo. Isso porque a tag nao envia o cabecalho Authorization, entao a imagem precisa ser buscada pela mesma chamada autenticada das demais.

GET /usuarios/{id}/foto

Acesso: o proprio dono ou admin

Devolve a foto. Responde 404 quando a conta nao tem foto.

Resposta

```
{ "foto": "..." }
```

PUT /usuarios/{id}/foto

Acesso: o proprio dono ou admin

Define a foto. Aceita PNG, JPEG, WEBP e GIF em data URI, ate cerca de 1 MB.

Requisicao

```
{ "foto": "..." }
```

Resposta

```
{ "ok": true }
```

SVG e recusado, e o conteudo precisa ser mesmo uma imagem -- nao basta o cabecalho dizer que e. A foto de um master so o proprio master altera.

DELETE /usuarios/{id}/foto

Acesso: o proprio dono ou admin

Remove a foto, voltando a inicial do nome.

Resposta

```
204 sem corpo
```

4. Modulos de governanca

Os modulos compartilham o mesmo conjunto de rotas, mudando apenas o nome no caminho. Os modulos disponiveis sao: acessos, mudancas, backup, restore, dicionario, integracoes, jobs.

Toda chamada exige login e passa pelo controle de acesso por modulo: uma conta so enxerga os modulos liberados no seu cadastro.

Rota	Faz
GET /{modulo}	Lista, com busca e paginacao.
POST /{modulo}	Cria um registro.
PUT /{modulo}/{id}	Atualiza um registro.
DELETE /{modulo}/{id}	Remove um registro.
DELETE /{modulo}/lote	Remove varios registros de uma vez.
GET /{modulo}/exportar	Exporta o modulo em JSON.

GET /jobs?busca=carga&pagina=1

Acesso: conta com acesso ao modulo

Exemplo de listagem. O parametro busca varre as colunas de texto do modulo.

Resposta

```
[
  {
    "id": 3,
    "nome": "Carga diaria de vendas",
    "frequencia": "Diario",
    "comando": "[{\"passo\":\"Extrair\",\"executa\":\"sp_extrai_vendas\"}]",
    "agendamentos": "[{\"inicio\":\"02:00\",\"fim\":\"03:30\"}]",
    "status": "Ativo",
    "criado_por": "admin"
  }
]
```

Em Jobs, os campos comando e agendamentos guardam listas em JSON. O portal cuida da leitura e da escrita; quem consome a API diretamente precisa tratar esses dois campos como texto JSON.

POST /acessos

Acesso: conta com escrita no modulo

Criacao de registro. O campo criado_por e definido pelo servidor e ignorado se vier na requisicao.

Requisicao

```
{
  "data": "2026-07-21",
  "usuario": "maria",
  "servidor": "SRV-BD-01",
  "objeto": "vendas",
  "nivel": "leitura",
  "status": "Ativo"
}
```

Resposta

```
{ "id": 42 }
```

5. Configuracao e apoio

Rota	Acesso	Faz
GET /dashboard/stats	autenticado	Numeros da tela inicial.
GET /dashboard/export	autenticado	Exporta o painel.
GET /tipos	autenticado	Listas editaveis do Cadastro.
POST /tipos	admin	Cria uma opcao de lista.
PUT /tipos/{id}	admin	Renomeia uma opcao.
DELETE /tipos/{id}	admin	Remove uma opcao.
GET /config/projeto	autenticado	Nome, logo e tempo de sessao.
PUT /config/projeto	admin	Altera a identidade do portal.
GET /config/email	admin	Parametros SMTP (sem a senha).
PUT /config/email	admin	Grava os parametros SMTP.
POST /config/email/testar	admin	Envia um e-mail de teste.
GET /seguranca/stats	admin	Bloqueios e tentativas recentes.
GET /auditoria	master	Trilha de auditoria.
GET /sistema/info	autenticado	Versao e motor de banco em uso.
GET /documentacao	autenticado	Manual de uso em PDF.
GET /documentacao/api	autenticado	Este manual, em PDF.
GET /documentacao/diagrama	autenticado	Dicionario de dados em PDF.

As tres rotas de documentacao tem versao em ingles com o sufixo -en: /documentacao/manual-en, /documentacao/api-en e /documentacao/diagrama-en.

6. Exemplo completo

Login e leitura de um modulo, com curl:

```
# 1) login
curl -s -X POST http://servidor/dados/api/auth/login \
  -H "Content-Type: application/json" \
  -d '{"usuario":"admin","senha":"SenhaForte1"}'

# 2) usa o token devolvido
curl -s http://servidor/dados/api/jobs \
  -H "Authorization: Bearer $TOKEN"
```